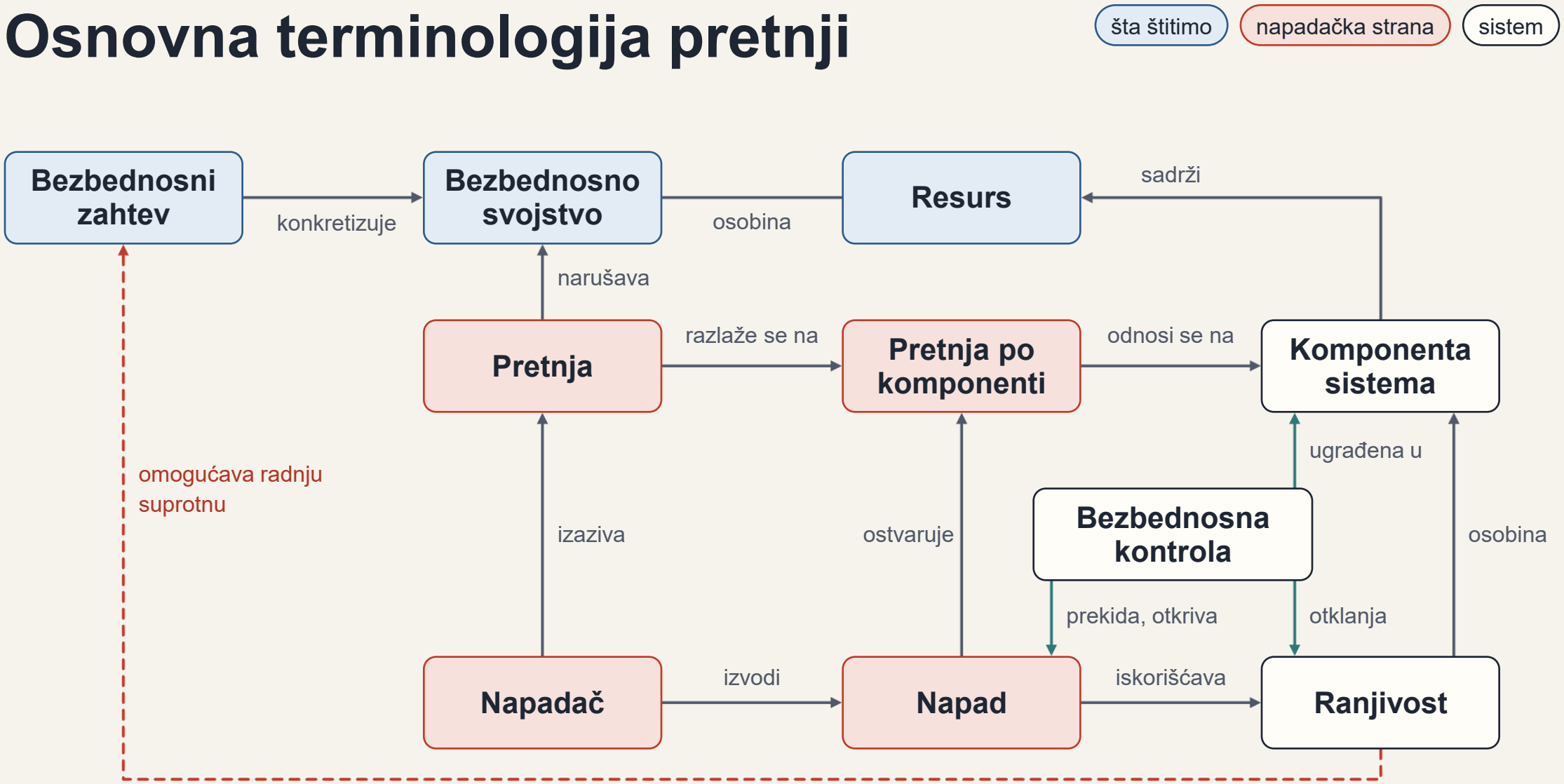
# Osnovna terminologija pretnji



# Resurs (asset)

**Resurs** je sve što ima vrednost za organizaciju i što doprinosi ostvarenju njenih ciljeva. Može biti materijalan (npr. oprema, prostorije, ljudi) ili nematerijalan (npr. podaci, softver, usluge, poslovni procesi, reputacija).

**PRIMER** dostava hrane

| | | | | |
|---|---|---|---|---|
| **lokacije kurira** podaci | **aplikacija** softver | **isporuka** proces | **kuriri** ljudi | **poverenje restorana** reputacija |

vrede jer služe cilju: obrok stiže do kupca, preduzeće profitira

**KONTRAPRIMER**



server za otpis sa obrisanim diskovima

# Bezbednosno svojstvo (security property)

> **Bezbednosno svojstvo** je osobina resursa od koje zavisi njegova vrednost za organizaciju, a koju mogu da naruše nedozvoljene radnje nad resursom.
> Osnovna su poverljivost, integritet, dostupnost i neporecivost.

**PRIMER** gradski vodovod



**očitavanje hlora**

**Integritet**
tačna vrednost

**Dostupnost**
stiže operateru

**Poverljivost**
manje bitna

**Neporecivost**
manje bitna

pogrešno ili zakasnelo očitavanje → pogrešno doziranje

→ **vrednost zavisi od integriteta i dostupnosti**

# Poverljivost (confidentiality)

> **Poverljivost** je bezbednosno svojstvo resursa da informacije koje sadrži nisu dostupne niti otkrivene licima, sistemima ili procesima koji za to nisu ovlašćeni.

**PRIMER** e-indeks

`e-indeks.rs/ocene?id=4172`

**Ocene: Ana Petrović**

| | |
|---|---|
| Baze podataka | 9 |
| Računarske mreže | 7 |
| Algoritmi | 10 |

Izmena broja u adresi otkriva studente tuđe ocene

→ **poverljivost narušena**

**KONTRAPRIMER**



nastavnik vidi ocene svog predmeta

→ **ovlašćen: poverljivost očuvana**

# Integritet (integrity)

> **Integritet** je bezbednosno svojstvo resursa da je tačan i potpun, te da nije izmenjen ni uništen na nedozvoljen način.

PRIMER e-indeks

**Baze podataka · Ana Petrović**

~~6~~ → 10

bez odluke nastavnika

niko ništa nije video → poverljivost netaknuta

→ **integritet narušen**

KONTRAPRIMER

**Baze podataka · Ana Petrović**

~~6~~ → 8

nastavnik, po zapisniku

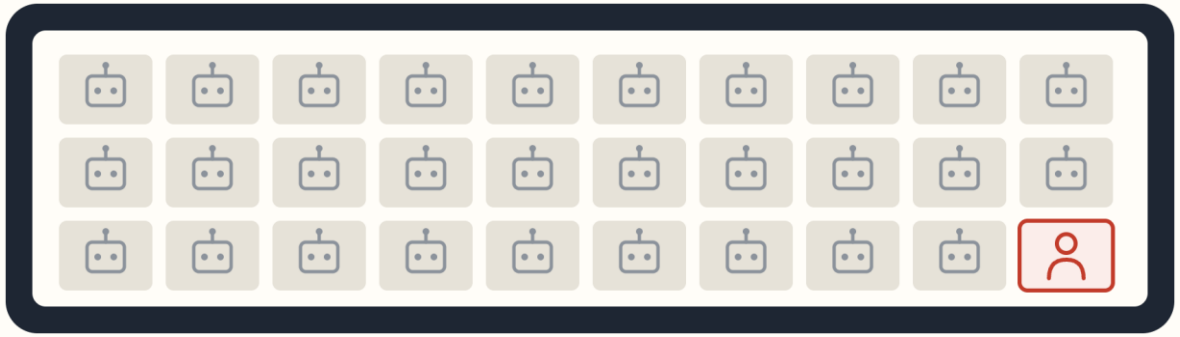
ispravka greške u upisu

→ **dozvoljena izmena: integritet očuvan**

# Dostupnost (availability)

> **Dostupnost** je bezbednosno svojstvo resursa
> da je pristupačan i upotrebljiv kada ga ovlašćeno lice ili sistem zatraži.

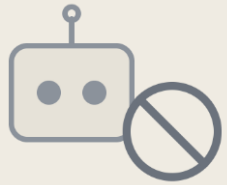
**PRIMER** dostava hrane · tablet restorana



aplikacija radi · prava porudžbina čeka iza 29 lažnih

→ **dostupnost narušena**

**KONTRAPRIMER**



bot odbijen pri registraciji

→ **nije ovlašćen korisnik: dostupnost nije narušena**

# Neporecivost (non-repudiation)

> **Neporecivost** je bezbednosno svojstvo resursa da se svaka radnja nad njim može pouzdano pripisati onome ko ju je izvršio, tako da on kasnije ne može uspešno da porekne da ju je izvršio.

**PRIMER** dostava hrane

*Nikad nisam preuzeo tu dostavu.*

kurir-17

```
DNEVNIK · #5521
12:30   restoran    PRIPREMLJENA
12:41   kurir-17    PREUZETA      obrisano
13:10   kupac       REKLAMACIJA
```

kurir briše svoj zapis iz dnevnika

→ **radnja se ne može pripisati: neporecivost narušena**

**KONTRAPRIMER**

```
DNEVNIK · #5530
13:05   operater-4  IZNOS 1200→120
```

iznos pogrešan, ali se zna ko ga je promenio

→ **integritet, ne neporecivost**

# Bezbednosni zahtev (security requirement)

> **Bezbednosni zahtev** je pravilo koje za određeni resurs utvrđuje ko sme, a ko mora moći da izvrši koje radnje nad njim. Svaki bezbednosni zahtev konkretizuje neko bezbednosno svojstvo tog resursa.

**PRIMER** e-indeks

**Ocene · integritet**

KO SME

**menja ih samo predmetni nastavnik**

**Ocene · dostupnost**

KO MORA MOĆI

**student vidi svoje ocene**

kaže šta mora da važi · ne kaže kako

→ **zahtev konkretizuje jedno svojstvo**

**KONTRAPRIMER**

MEHANIZAM

**„Sistem koristi dvofaktorsku prijavu.“**

kaže kako, ne šta mora da važi

→ **bezbednosna kontrola, ne zahtev**

# Šta štitimo u e-indeksu

| RESURS | Poverljivost | Integritet | Dostupnost | Neporecivost |
|---|---|---|---|---|
| **Ocene**<br>podaci | vide samo student i nastavnik | menja samo nastavnik | student vidi svoje | zna se ko je upisao |
| **Lični podaci**<br>podaci | vidi studentska služba | menja studentska služba | služba ih otvara pri upisu | — |
| **Prijava ispita**<br>proces | — | student prijavljuje samo sebe | radi do kraja roka | student ne može da porekne prijavu |

**resurs × svojstvo → bezbednosni zahtev** — svojstvo nije bitno za taj resurs

# Komponenta sistema (system component)

> **Komponenta sistema** je deo sistema organizacije u kom se resurs skladišti, obrađuje, ili kroz koji se prenosi. Može biti softverska, hardverska ili mrežna, ali i ljudska ili fizička, kao zaposleni koji obrađuje podatke ili arhiva papirne dokumentacije.

**PRIMER** dostava hrane · put jedne porudžbine




resurs porudžbina prolazi kroz svih pet

→ **komponente: mesta gde resurs živi i putuje**

**KONTRAPRIMER**



laptop napadača · izvan granice sistema organizacije

# Napadač (attacker)

> **Napadač** je lice, grupa ili organizacija koja namerava da naruši bezbednosna svojstva resursa organizacije kao sredstvo za ostvarenje sopstvenog cilja. Taj cilj je motivacija napadača: finansijska korist, informacije, ideološki ili politički uticaj, osveta, lično zadovoljstvo ili prinuda.

**PRIMER** gradski vodovod

| Motivacija | Napadač | Resurs | Svojstvo |
|---|---|---|---|
| novac | ransomware grupa | sistem naplate | dostupnost |
| ideologija | haktivisti | pumpe | dostupnost |
| osveta | bivši inženjer | doziranje hlora | integritet |
| informacije | strana služba | mapa cevovoda | poverljivost |

→ **motivacija usmerava napadača ka resursu**

**KONTRAPRIMER**

**operater deli lozinku kolegi** · cilj: brža smena, narušavanje je usput

**pentesteri po ugovoru** · postoji dozvola

→ **nisu napadači**

# Pretnja (threat)

> **Pretnja** je mogući događaj u kom napadač
> narušava određeno bezbednosno svojstvo određenog resursa.

**PRIMER** dostava hrane

| NAPADAČ | + | SVOJSTVO | + | RESURS |
|---|---|---|---|---|
| **haktivisti** | | **dostupnost** | | **naručivanje** |
| protest kurira | | svojstvo | | proces |

**= pretnja**

**KONTRAPRIMER**

NAPADAČ —



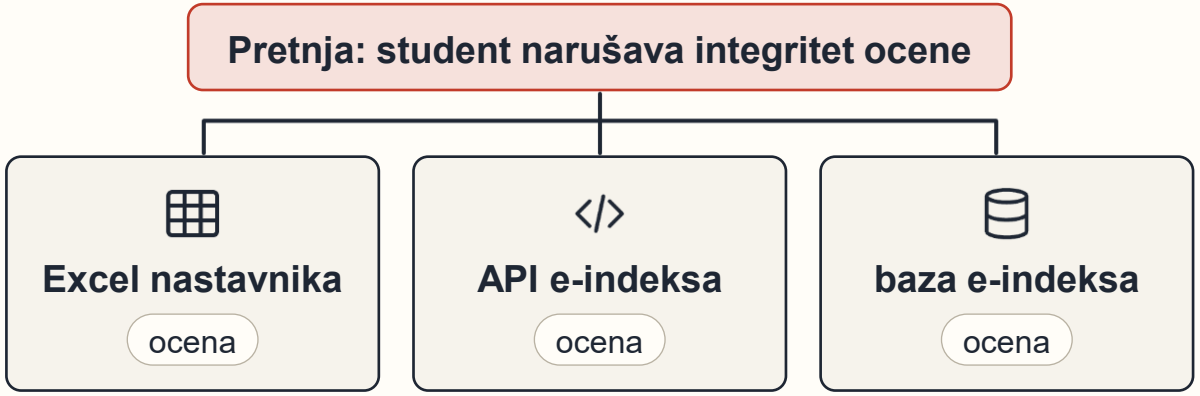
kvar diska u data centru

→ **nema napadača: nije pretnja**

# Pretnja po komponenti (component-level threat)

> **Pretnja po komponenti** je pretnja ograničena na jednu komponentu sistema u kojoj se ugroženi resurs nalazi.

PRIMER e-indeks




→ **1 pretnja, 3 pretnje po komponenti**

KONTRAPRIMER



mejl nastavnika
napadač ga možda koristi, ali ne sadrži ocenu

# Ranjivost (vulnerability)

**Ranjivost** je osobina komponente sistema zbog koje komponenta omogućava radnju suprotnu nekom bezbednosnom zahtevu, a kojom napadač može da ostvari pretnju.
Nastaje u dizajnu, implementaciji, konfiguraciji ili načinu upotrebe komponente.

**PRIMER** gradski vodovod

**ZAHTEV**
**doziranje hlora menja samo dežurni operater**



**SCADA · DOZIRANJE**
`korisnik: admin`
`lozinka: admin`
dostupan sa interneta

fabrička lozinka + izložen internetu

→ **omogućava radnju suprotnu zahtevu: ranjivost**

**KONTRAPRIMER**

**javni sajt vodovoda** · svima dostupan, i treba

**bag u isključenom modulu** · nema pristupa

ne omogućavaju nijednu nedozvoljenu radnju

→ **nisu ranjivosti**

# Napad (attack)

> **Napad** je niz radnji koje napadač izvodi ili navodi druge da izvedu, u pokušaju da ostvari jednu ili više pretnji po komponenti. U tom nizu napadač po potrebi iskorišćava ranjivosti komponenti da bi stekao mogućnosti koje nema, dok ne bude u stanju da naruši bezbednosno svojstvo ciljnog resursa.

**PRIMER** e-indeks

**napadač:** student · **cilj:** stipendija




**→ ostvaruje pretnju po komponenti: integritet ocene u bazi e-indeksa**

# Napad: granični slučajevi

PRIMER

## Neuspeo pokušaj



nastavnik prepozna lažnu stranicu

**→ ipak napad: napad je pokušaj**

PRIMER

## Insajder



asistent sa pravom upisa sam menja ocenu

**→ nijedan korak iskorišćavanja, ipak napad**

KONTRAPRIMER

## Pentest po ugovoru



isti koraci, uz dozvolu fakulteta

**→ nema napadača: nije napad**

ŠTA PREDUZIMAMO

# Bezbednosna kontrola (security control)

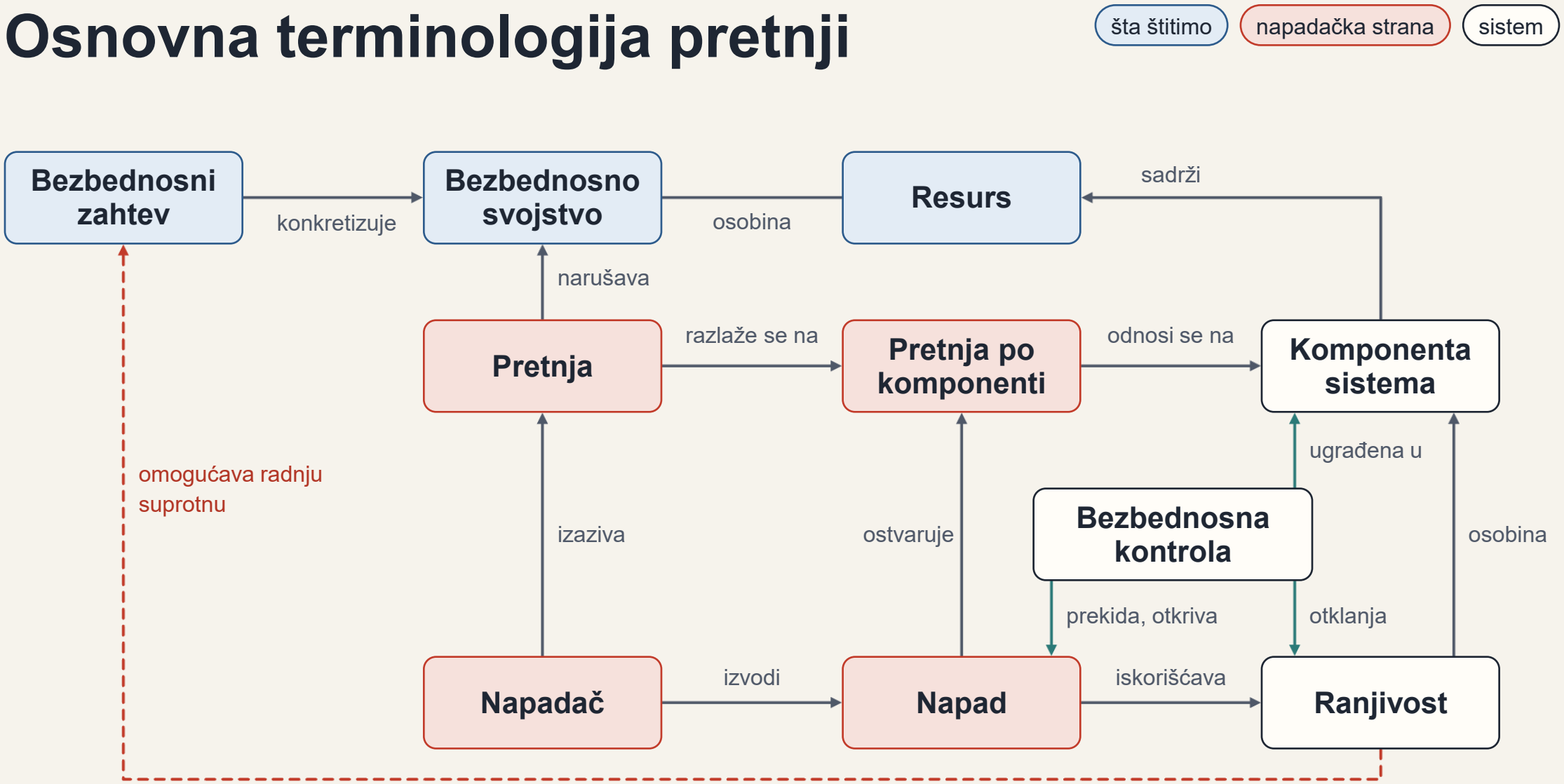
> **Bezbednosna kontrola** je mehanizam ugrađenu u komponentu sistema ili posebna komponenta, kojom organizacija sprečava, otkriva ili ispravlja narušavanje bezbednosnih svojstava resursa. Može biti tehnička, organizaciona, kadrovska ili fizička.

**PRIMER** gradski vodovod

| Kontrola | Komponenta | Dejstvo | Priroda |
|---|---|---|---|
| VPN ispred SCADA panela | SCADA panel | preventivna | tehnička |
| dupla potvrda doziranja | operateri | preventivna | organizaciona |
| zaključana pumpna stanica | pumpna stanica | preventivna | fizička |
| alarm za skok hlora | SCADA | detektivna | tehnička |
| kopija konfiguracije | novi sistem za kopije | korektivna | tehnička |

→ **otklanja ranjivosti i otkriva ili sprečava napade**

# Osnovna terminologija pretnji




**Kako širimo?** Tipovi komponenti, ranjivosti, kontrola; Konkretne -||- i napadi